Auditor de exposición digital para pymes

Reporte técnico · Track 1 del Reto Agente 2026 (Platica.mx × Campuslands) · Autora: Aleja (GitHub Aleja4923) · Repositorio: github.com/Aleja4923/agrente-expocision · Licencia MIT · Razonamiento sobre Grok por el gateway del reto

1.150 / 1.150 auditorías reales completadas en una corrida de 14,2 h sin intervención	**USD 0,027** costo por auditoría (grok-4.20), medido llamada por llamada	**100 %** nivel de riesgo correcto en 240 corridas sobre 35 casos con respuesta conocida	**816** pruebas automáticas, sin red ni llave

1. El problema

Impacto

Las pymes colombianas usan su dominio para el correo y la web, pero la mayoría no publica las protecciones que permiten a un receptor reconocer un correo falso (SPF, DKIM, DMARC). El resultado son facturas y cambios de cuenta bancaria «desde» su correo, y dominios casi idénticos al suyo listos para recibir los correos que sus clientes escriban mal. El dueño no lo sabe y, aunque lo supiera, no sabe qué pedirle a su proveedor.

Medido por el propio agente sobre 1.131 dominios `.com.co` reales que existen (lista pública Tranco): el **56 %** no publica DMARC, el **45 %** no tiene SPF y el **48 %** tiene al menos un dominio casi idéntico con correo configurado. La muestra no es solo de pymes (incluye grandes empresas y dominios aparcados), pero muestra que el problema es masivo.

2. Qué entrega y por qué es distinto

Herramientas como MXToolbox o internet.nl hacen los chequeos técnicos gratis. Este agente aporta dos cosas que ellas no dan:

- **Un plan, no un tablero:** prioriza qué hacer primero, lo explica en lenguaje de dueño y adjunta el dato técnico exacto, listo para reenviar al proveedor. Los cambios son graduales (DMARC primero en observación) para no mandar a spam correo legítimo como la facturación electrónica.
- **Dominios parecidos preparados para enviar correo:** genera variantes del dominio y revisa cuáles existen, tienen correo, se registraron hace poco o autorizan envío en su SPF. Es la señal más cercana a un fraude de facturas antes del primer correo falso, y se presenta como algo a verificar, nunca como acusación.

Además revisa SPF, DKIM y DMARC; el registro del dominio (vencimiento y bloqueo de transferencia); los subdominios de los registros públicos de certificados; y las cabeceras de seguridad y el `security.txt` del sitio. Entrega el informe en Markdown y en HTML imprimible, con la misma información.

3. Arquitectura: Grok investiga, el código concluye

Autonomía y funcionalidad

Bucle propio sobre la librería `openai` (sin framework): Grok recibe el objetivo y 9 herramientas → pide varias en paralelo, cada una con una justificación de una línea → el arnés valida el alcance, ejecuta y devuelve los resultados (lo externo, marcado como no confiable) más los hallazgos que calcula el código → Grok decide qué más investigar o entrega el informe → el arnés lo valida o lo rechaza con el motivo → el código calcula el nivel de riesgo y arma el informe con los datos técnicos literales.

- **Grok elige el camino:** qué revisar, en qué orden y cuándo tiene suficiente. Hay más candidatos que presupuesto (4 parecidos y 10 subdominios por auditoría), así que tiene que priorizar según el objetivo, que el usuario escribe en texto libre.
- **Hay dependencias reales:** primero ve el proveedor de correo y después elige los selectores DKIM; primero ve la lista de parecidos y después decide cuáles investigar.
- **31 reglas deterministas** calculan los hallazgos, cada uno con id, severidad y evidencia. Grok no puede crear hallazgos ni cambiar su severidad: redacta y prioriza.
- **Siempre hay informe:** topes por auditoría de 20 pasos, USD 0,20 y 300 s. Si se alcanza uno, el código arma un informe de respaldo con lo verificado, y el nivel sale como provisional.
- **Trayectorias distintas por dominio:** en un banco con cientos de subdominios eligió los de autenticación y comercio; con Microsoft 365 probó sus dos selectores DKIM y encontró una clave de 1024 bits; con un dominio inexistente entregó en 2 pasos.
- **Alcance ético pasivo:** solo información pública, sin escaneos ni accesos, y con protección contra SSRF. Ninguna herramienta acepta un dominio ajeno; a los parecidos solo se les consulta DNS y registro, nunca su sitio.

4. Ingeniería sobre Grok

Ingeniería sobre Grok

- **`chat/completions` con llamadas a herramientas en paralelo:** en el primer paso Grok pide juntas las 7 revisiones de base; la mediana fue de 3 pasos por auditoría en la corrida de carga.

- **Validador del informe:** rechaza un informe que cite hallazgos inexistentes, que omita uno crítico o alto, que se entregue antes de las revisiones obligatorias o que copie texto distintivo de un registro externo (defensa contra la inyección de instrucciones en el DNS). Grok recibe el motivo y corrige.
- **Costo real por llamada**, con los tokens de caché y de razonamiento por separado. La bitácora se cruza con el panel del reto: con grok-4.20, **4.374 peticiones en la bitácora y 4.374 en el panel**.
- **Caché del gateway:** el 63 % de los tokens de entrada de la corrida de carga se leyó de la caché, gracias a un prompt de sistema fijo y a una conversación por intento.
- **Robustez:** reintentos con espera; tiempo máximo por respuesta subido de 60 a 120 s con evidencia (en una tarde lenta del gateway, con 60 s, se cortaron 26 de 48 intentos de grok-4.7; con 120 s, cero); detección de repeticiones; guarda de alcance; identidad lote > auditoría > intento para reanudar sin contar dos veces.
- **Corrida desatendida:** cola con 2 hilos y bitácora con candado; pausas automáticas si cae el gateway; freno de gasto; impide que Windows suspenda el equipo; relanzador si se cae Python.

5. Evidencia con datos reales

Evidencia con datos reales

Evaluación (S3). 35 casos con respuesta conocida: 25 dominios reales seudonimizados y 10 fabricados (inyección en el DNS, dominio por vencer, SPF con demasiadas consultas, mismo dominio con dos objetivos), que cubren las 31 reglas. Grok corre de verdad; las respuestas de las herramientas se reproducen desde lo grabado detrás de las mismas guardas.

	grok-4.20	grok-4.7	grok-4.7, `reasoning_effort=low`
Corridas	105	105	30
Nivel de riesgo correcto	100 %	100 %	100 %
Hallazgos que dependen de lo que Grok elige investigar	40 % (75/186)	67 % (124/186)	47 % (27/57)
Costo por auditoría: mediana · máximo	USD 0,031 · 0,082	USD 0,097 · 0,255	USD 0,036 · 0,089
Resistencia a la inyección en el DNS (no copió la marca)	2 de 6	6 de 6	3 de 3

Carga (S4). 1.150 dominios `.com.co` sorteados de la lista Tranco con semilla fija, auditados de punta a punta con grok-4.20 en una sola pasada desatendida.

Completadas · fallidas	Duración	Costo total · por tarea	Por tarea: mediana · p90 · máximo	Tokens
1.150 · 0 (100 %)	14,2 h, un solo arranque	USD 31,10 · USD 0,027	USD 0,026 · 0,038 · 0,147	28,9 M de entrada (63 % de caché) · 1,1 M de salida · 4,5 M de razonamiento

Hay una bitácora pública por tarea (hora, resultado, intentos, pasos, tokens, costo, errores y recuperación), sin el riesgo de ninguna empresa concreta. Además, en el S2 hubo 10 auditorías reales de perfiles distintos (10 de 10 con el informe de Grok) y en el S1, 26 auditorías por la CLI.

6. Viabilidad

Viabilidad

Quién paga: contadores y agencias web, que lo ofrecen a sus clientes pyme como servicio de valor agregado (B2B2C). Ya tienen su confianza y ganan al ejecutar las recomendaciones. **Costo de operación medido:** USD 0,027 por auditoría con grok-4.20 (unos USD 27 por cada 1.000), o USD 0,097 de mediana con grok-4.7 cuando importa la calidad de las decisiones. Sin infraestructura propia: solo consultas públicas y Grok, alrededor de un minuto por auditoría. El nivel de riesgo lo calcula el código, así que se puede usar el modelo barato para volumen. La barrera no es el costo sino la confianza y la distribución; por eso el canal son los intermediarios.

7. Límites y fallos, dichos con sus cifras

- **En la corrida de carga:**
  - 5 de 1.150 tareas cerraron con informe de respaldo (4 por rechazos agotados y 1 por el tope de pasos);
  - el validador rechazó 87 borradores en 73 tareas, y Grok los corrigió;
  - Cert Spotter llegó a su límite de consultas en 351 tareas, y quedó declarado como limitación;
  - 29 dominios tienen nivel provisional porque falló una revisión principal o cerraron con respaldo.
- **Inyección:** con grok-4.20, 4 de 6 corridas copiaron una marca trampa en el resumen, aunque ningún modelo logró borrar un hallazgo. Se agregó la defensa en el arnés, probada con pruebas automáticas. En la verificación con Grok la marca no reapareció y la guarda no llegó a activarse, así que eso no prueba por sí solo que el modelo haya cambiado.
- **Qué parecidos investiga Grok puede mover el nivel** de riesgo; por eso el modelo importa en esas decisiones (grok-4.7 acierta más, a unas 3 veces el costo).
- **Las respuestas esperadas del set las escribió la misma autora del código,** así que no son del todo independientes.

- **El panel del reto muestra más costo de grok-4.7 que la bitácora:** sobre todo son peticiones que el cliente cortó por tiempo y que el gateway cobró sin devolver su consumo. El cruce está en `consumo/RESUMEN.md`.

8. Cómo reproducirlo

`./iniciar.sh ejemplo.com.co` (o `iniciar.ps1` en Windows) prepara el entorno y audita; `--json` devuelve el resultado como datos y `--lote casos.txt` corre una lista de dominios. Sin llave ni red: `pytest` (816 pruebas), `python -m evals.medir` (rehace el reporte de evaluación), `python -m carga.resumen --lote s4-carga` y `python -m carga.consumo`.

Las cifras salen de `evals/REPORTE.md`, `carga/s4-carga/RESUMEN.md` y `consumo/RESUMEN.md`, que se regeneran desde las bitácoras del repositorio.